

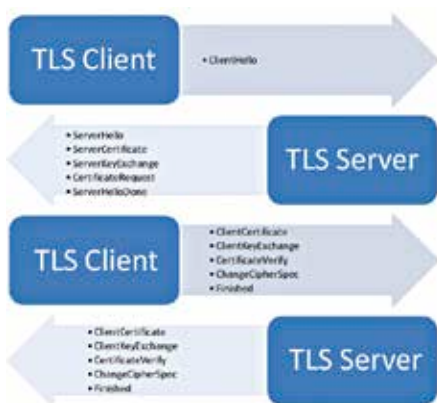
can check the URLs of a few consecutive image uploads to figure out the directory address and naming pattern that the upload follows.

Then, instead of uploading an image, the same user can upload a shell file (think of it like a backdoor access to servers; somewhat like a cPanel within a PHP file). Now, when the user hits that URL, instead of getting the image he would get a control panel that would let him take multiple actions that could create a lot of chaos at the very least.

A simple way to make sure this does not happen is to enforce a check for filetypes being uploaded. To reduce the overhead, the check should ALLOW only certain file types and block everything else. Also, this block should not happen on the user end, as then it can be easily detected and worked around by looking at the source of any page. On the other hand, in no situation should the file be brought to the back end.

Transport Layer security vs Secure Socket layer

If the two terms above seem alien to you, just look at their abbreviations - TLS and SSL, the two protocols used for establishing secure and verified connections between websites, apps and web servers. And you clearly need to choose one over the other.



The exchange involved in a TLS authentication

SSL is the precursor to TLS and although it is more widespread, it is definitely less secure. Recently, the POODLE vulnerability in SSL 3.0 has been exposed that allows access to sensitive information like passwords, cookies and more. This has caused a widespread shift to TLS and this one time, you should follow the crowd.

When setting up your website, make sure that you manually configure your webserver, especially you are going to deal with sensitive information like the ones mentioned above. And when you do, definitely go for TLS 1.2 even if it comes at an added premium.